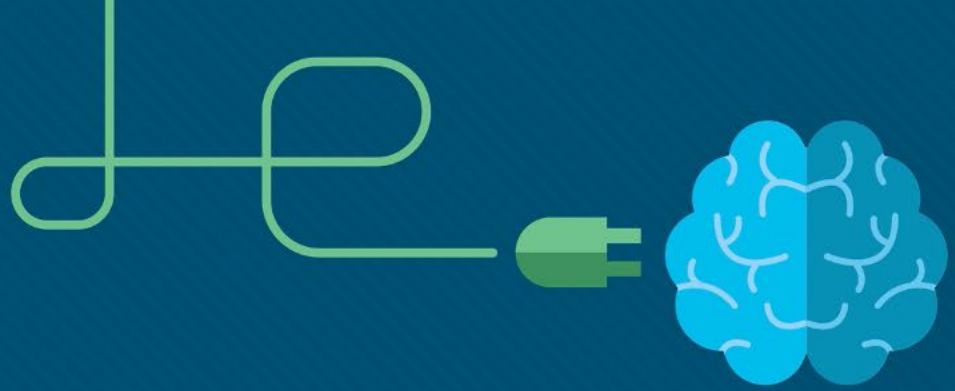


Week 5

Cloud & IoT Security



Tauseef Ahmed, PhD
tahmed4@uel.ac.uk

Lecture Objectives

Topic Title	Topic Objective
Virtualization and Cloud Computing	Describe ways to manage threats to the private and public cloud.
The Domains of Cloud Security	Explain the domains of cloud security.
Cloud Infrastructure Security	Explain mitigation of threats to the cloud platform infrastructure.
Cloud Application Security	Recommend cloud security applications.
Cloud Data Security	Explain how to secure cloud data.
Protecting VMs	Explain how to secure VM instances.
IoT Security	Explain the basic IoT network and its security.

1. Virtualization and Cloud Computing

Virtualization

- A technology that provides an abstraction of the resources used by some software which runs in a simulated environment called a virtual machine (VM)
- Benefits include better efficiency in the use of the physical system resources
- Provides support for multiple distinct operating systems and associated applications on one physical system
- Raises additional security concerns

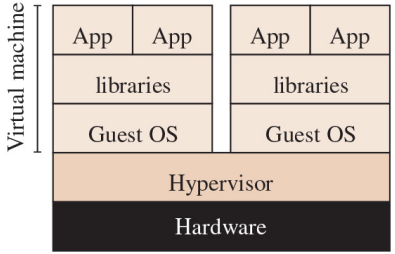
Hypervisor

- Software that sits between the hardware and the VM s
- Acts as a resource broker
- It allows multiple V M s to safely coexist on a single physical server host and share that host's resources
- Virtualizing software provides abstraction of all physical resources and thus enables multiple computing stacks, called virtual machines, to be run on a single physical host
- Each VM includes an OS, called the guest OS
  - This OS may be the same as the host OS, if present, or a different one

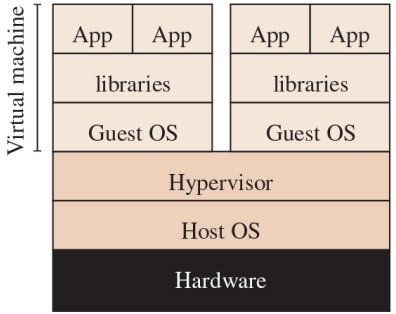
Hypervisor Functions

- The principal functions performed by a hypervisor are:
  - Execution management of V M s
  - Devices emulation and access control
  - Execution of privileged operations by hypervisor for guest V M s
  - Management of VM s (also called VM lifecycle management)
  - Administration of hypervisor platform and hypervisor software

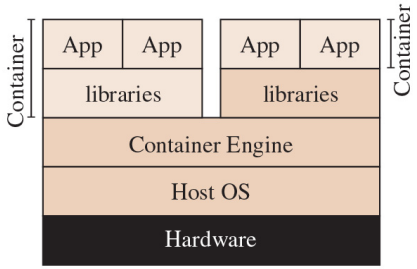
Comparison of Virtual Machines and Containers



(a) Type 1 hypervisor (native virtualization)



(b) Type 2 hypervisor (hosted virtualization)



(c) Container (application virtualization)

Virtualized Systems

- In virtualized systems, the available hardware resources must be appropriately shared among the various guest OSs
- These include CPU, memory, disk, network, and other attached devices
- CPU and memory are generally partitioned between these, and scheduled as required
- Disk storage may be partitioned, with each guest having exclusive use of some disk resources
- Alternatively, a “virtual disk” may be created for each guest, which appears to it as a physical disk with a full file-system but is viewed externally as a single ”disk image” file on the underlying file-system
- Attached devices such as optical disks or USB devices are generally allocated to a single guest OS at a time

Software-Defined Networks (SDNs)

- SDN s enable network segments to logically span multiple servers within and between data centers, while using the same underlying physical network
- There are several possible approaches to providing SDNs, including the use of overlay networks
  - These abstract all layer 2 and 3 addresses from the underlying physical network into whatever logical network structure is required
  - This structure can be easily changed and extended as needed
  - The IETF standard DOVE (Distributed Overlay Virtual Network) which uses VXLAN (Virtual Extended Local Area Network) can be used to implement such an overlay network
  - With this flexible structure, it is possible to locate virtual servers, virtual IDSs, and virtual firewalls anywhere within the network as required

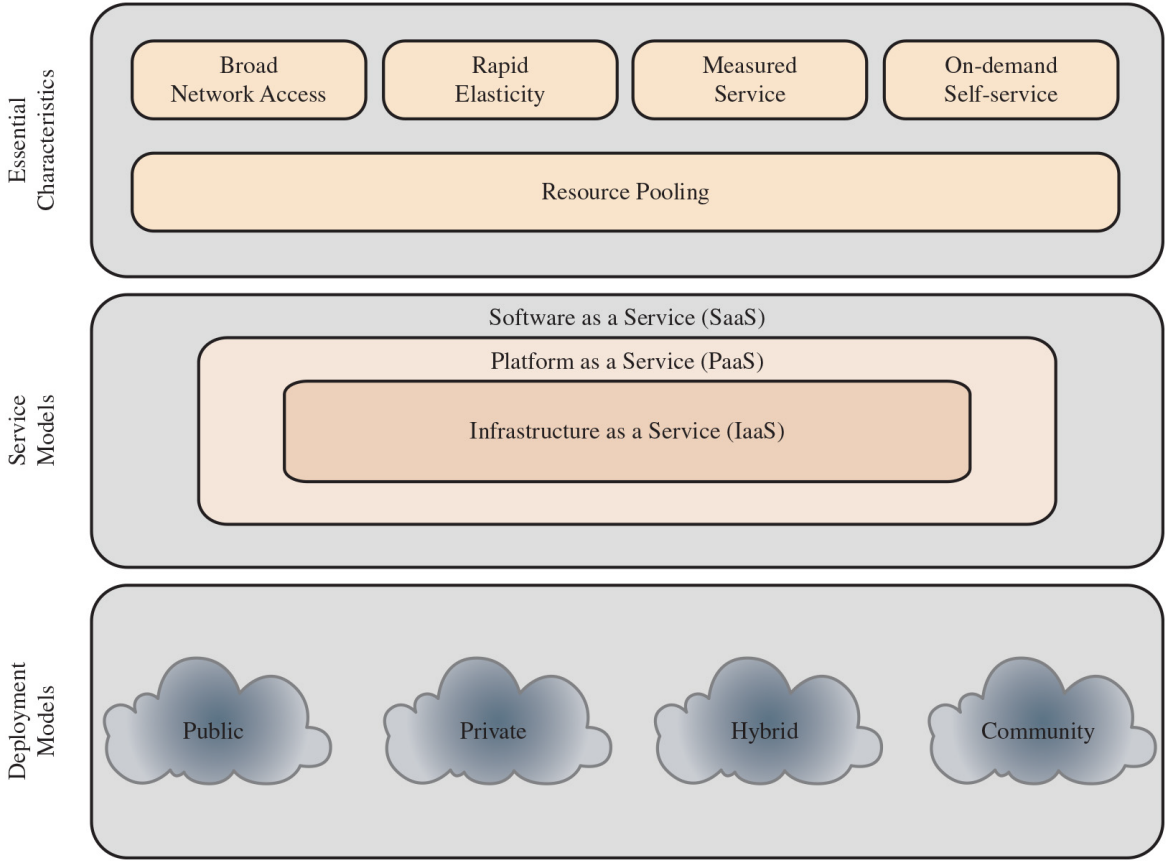
Containers

- A recent approach to virtualization is known as container virtualization or application virtualization
- In this approach, software known as a virtualization container, runs on top of the host OS kernel and provides an isolated execution environment for applications
- Unlike hypervisor-based VMs, containers do not aim to emulate physical servers
- All containerized applications on a host share a common OS kernel
- For containers, only a small container engine is required as support
- Containerization sits between the OS and applications and incurs lower overhead but potentially introduces greater security vulnerabilities

Cloud Computing Definition

- NIST defines cloud computing in NIST SP-800-145 (The NIST Definition of Cloud Computing, September 2011) as follows:
- “Cloud computing: A model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This cloud model promotes availability and is composed of five essential characteristics, three service models, and four deployment models.”

Cloud Computing Elements



Necessities

Which?

How?

Software as a Service (SaaS)

- SaaS provides service to customers in the form of software, specifically application software, running on and accessible in the cloud
- It enables the customer to use the cloud provider's applications running on the provider's cloud infrastructure
  - The applications are accessible from various client devices through a simple interface, such as a Web browser
  - Instead of obtaining desktop and server licenses for software products it uses, an enterprise obtains the same functions from the cloud service
- The use of SaaS avoids the complexity of software installation, maintenance, upgrades, and patches
- Examples of this service are Google Gmail, Microsoft 365, Salesforce, Citrix GoToMeeting, and Cisco WebEx

Platform as a Service (PaaS)

- A PaaS cloud provides service to customers in the form of a platform on which the customer's applications can run
- PaaS enables the customer to deploy onto the cloud infrastructure customer-created or acquired applications
- A PaaS cloud provides useful software building blocks plus a number of development tools, such as programming language tools, run-time environments, and other tools that assist in deploying new applications
- In effect, PaaS is an operating system in the cloud
- It is useful for an organization that wants to develop new or tailored applications while paying for the needed computing resources only as needed, and only for as long as needed
- Examples of PaaS include AppEngine, Engine Yard, Heroku, Microsoft Azure, Force.com, and Apache Stratos

Infrastructure as a Service (IaaS)

- With IaaS, the customer has access to the resources of the underlying cloud infrastructure
- The cloud service user does not manage or control the resources of the underlying cloud infrastructure, but has control over operating systems, deployed applications, and possibly limited control of select networking components
- IaaS provides virtual machines and other virtualized hardware and operating systems
- IaaS offers the customer processing, storage, networks, and other fundamental computing resources so the customer is able to deploy and run arbitrary software, which can include operating systems and applications
- IaaS enables customers to combine basic computing services, such as number crunching and data storage, to build highly adaptable computer systems
- Examples of IaaS are Amazon Elastic Compute Cloud, Microsoft Windows Azure, Google Compute Engine, and Rackspace

Cloud Deployment Models

- The four most prominent deployment models for cloud computing are:
  - Public cloud
  - Community cloud
  - Private cloud
  - Hybrid cloud

Public Cloud

- A public cloud infrastructure is made available to the general public or a large industry group, and is owned by an organization selling cloud services
  - The cloud provider is responsible both for the cloud infrastructure and for the control of data and operations within the cloud
- A public cloud may be owned, managed, and operated by a business, academic, or government organization, or some combination of them
  - All major components are outside the enterprise firewall, located in a multitenant infrastructure
  - Applications and storage are made available over the Internet via secured I P, and can be free or offered at a pay-per-usage fee
- The major advantage of the public cloud is cost
- The principal concern is security

Private Cloud

- A private cloud is implemented within the internal I T environment of the organization
- The organization may choose to manage the cloud in house or contract the management function to a third party
- Cloud servers and storage devices may exist on premise, off premise, or both
- Private clouds can deliver I a a S internally to employees or business units through an intranet or the Internet via a virtual private network (V P N), as well as software or storage as services to its branch offices
- Examples of services delivered through the private cloud include database on demand, email on demand, and storage on demand
- A key motivation for opting for a private cloud is security
- Other benefits include easy resource sharing and rapid deployment to organizational entities

Community Cloud

- A community cloud shares characteristics of private and public clouds
  - Has restricted access like a private cloud
  - The cloud resources are shared among a number of independent organizations like a public cloud
- The organizations that share the community cloud have similar requirements and, typically, a need to exchange data with each other
  - An example would be the healthcare industry
- The cloud infrastructure may be managed by the participating organizations or a third party, and may exist on premise or off premise
  - In this deployment model, the costs are spread over fewer users than a public cloud so only some of the cost savings potential of cloud computing are realized

Hybrid Cloud

- The hybrid cloud infrastructure is a composition of two or more clouds (private, community, or public) that remain unique entities but are bound together by standardized or proprietary technology that enables data and application portability
- With a hybrid cloud solution, sensitive information can be placed in a private area of the cloud, and less sensitive data can take advantage of the benefits of the public cloud
- A hybrid public/private cloud solution can be particularly attractive for smaller business
- Many applications for which security concerns are less can be offloaded at considerable cost savings without committing the organization to moving more sensitive data and applications to the public cloud

Comparison of Cloud Deployment Models

	Private	Community	Public	Hybrid
Scalability	Limited	Limited	Very high	Very high
Security	Most secure option	Very secure	Moderately secure	Very secure
Performance	Very good	Very good	Low to medium	Good
Reliability	Very high	Very high	Medium	Medium to high
Cost	High	Medium	Low	Medium

Top Threats to Cloud Computing

Cloud computing is susceptible to many of the same threats that affect physical enterprise networks. However, the cloud environment also introduces unique threats.

For instance, if a threat actor successfully compromises a cloud resource, they could do the following:

- Use the cloud computing resources to target other online entities.
- Host malware on respected cloud providers that will appear harmless or even legitimate.
- Abuse the cloud services to launch DDoS attacks, host pirated contents, send email spam, and conduct phishing campaigns.

Top Threats to Cloud Computing

The following lists some threats associated with cloud computing.

Threat	Description
Data breaches	These occur when protected sensitive data is accessed by an unauthorized entity.
Cloud misconfiguration	This occurs when the cloud computing resource is set up incorrectly, making it vulnerable to attacks.
Poor cloud security architecture strategy	Private cloud security is the responsibility of the organization. However, security for public clouds, hybrid clouds, and community clouds becomes a shared responsibility between the organization and the provider. This can introduce vulnerabilities if the cloud security architecture is not fully understood or correctly implemented.
Compromised account credentials	This occurs when user accounts or access privileges are not properly secured and are hijacked by threat actors. This can lead to a major security threat if the account has high privileges. For example, in public clouds a service account has the highest privilege for accessing and managing cloud assets. A hijacked service account would enable a threat actor to control all cloud resources.

Top Threats to Cloud Computing (Cont.)

The following lists some threats associated with cloud computing.

Threat	Description
Insider threat	This occurs when an employee, contractor, or business partner maliciously or unintentionally compromise the cloud service.
Insecure software user interface (UI) or application programming interface (API)	Cloud computing uses software UIs and APIs for customers to interact with their cloud services. These interfaces are the most exposed points to the internet and therefore, they are targets for threat actors.
Limited cloud usage visibility	This occurs when the cloud client does not have full visibility into the cloud service, making the identification of safe or malicious files more difficult.

2. The Domains of Cloud Security

Domains of Cloud Security

There are many resources available promoting cloud computing security.

- A widely respected and referenced resource is the Security Guidance for Critical Areas of Focus in Cloud Computing v4 document.
    - Developed by the Cloud Security Alliance (CSA), it promotes best practices to provide security assurance within the cloud computing domains.
    - Specifically, the document covers 14 domains of cloud security.

https://cloudsecurityalliance.org/

Domains of Cloud Security

Domain Title	Description
Cloud Computing Concepts and Architectures	The domain defines cloud computing terminology and details the overall logical and architectural frameworks used in the Security Guidance document.
Governance and Enterprise Risk Management	The domain describes four areas impacted by cloud computing: • Governance • Enterprise Risk Management • Information Risk Management • Information Security
Legal Issues, Contracts, and Electronic Discovery	The domain describes legal issues associated with cloud computing including the moving of data to the cloud, contracting with cloud service providers, and handling electronic discovery requests in litigation.
Compliance and Audit Management	The domain describes challenges of delivering, measuring, and communicating compliances when organizations migrate from traditional data centers to the cloud.
Information Governance	The domain describes the need to ensure that the use of data and information complies with organizational policies, standards, and strategy including regulatory, contractual, and business objectives.

Domains of Cloud Security (Cont.)

Domain Title	Description
Management Plane and Business Continuity	The domain describes the need to secure the cloud computing management plane (i.e., the protocols and resources used to manage the cloud). It also describes business continuity and disaster recovery procedures to be used by the cloud provider and the cloud client.
Security as a Service	The domain covers the continually evolving security services delivered from the cloud.
Infrastructure Security	The domain describes cloud-specific aspects of infrastructure security and the foundation for operating securely in the cloud.
Virtualization and Containers	The domain describes the need to secure the virtualization technology and virtual assets which are the foundation for cloud computing.
Incident Response	The domain describes the critical aspects of incident response (IR) including the Incident Response Lifecycle and considerations for responders as they work in a cloud environment.
Application Security	The domain provides guidance on how to securely build and deploy applications in cloud computing environments, specifically for PaaS and IaaS.

Domains of Cloud Security (Cont.)

Domain Title	Description
Data Security and Encryption	Data Security should be risk-based since it is not appropriate to secure everything equally. The domain describes those controls related to securing the data itself, of which encryption is one of the most important.
Identity, Entitlement, and Access Management (IAM)	The domain describes how cloud identity is different than traditional identity management.
Related Technologies	The domain provides background and recommendations for technologies that rely nearly exclusively on cloud computing to operate and for technologies that do not necessarily rely on cloud but are commonly seen in cloud deployments.

Domains of Cloud Security (Cont.)

- Infrastructure Security
- Virtualization and Containers
- Application Security
- Data Security and Encryption
- Security as a Service

3. Cloud Infrastructure Security

Infrastructure Security

- The **Infrastructure Security** domain describes cloud-specific aspects of infrastructure security and the foundation for operating securely in the cloud.

- Cloud infrastructure is the foundation on which virtualized cloud resources such as computing, networking, and data storage are built and deployed.

- There are two major layers to infrastructure in cloud computing:

    - The physical and logical compute (CPU, memory, etc.), networks, and storage are combined to create a cloud.
    - The virtual infrastructure managed by a cloud user, that is, the compute, network, and storage assets they access from the resource pools.

Infrastructure Security (Cont.)

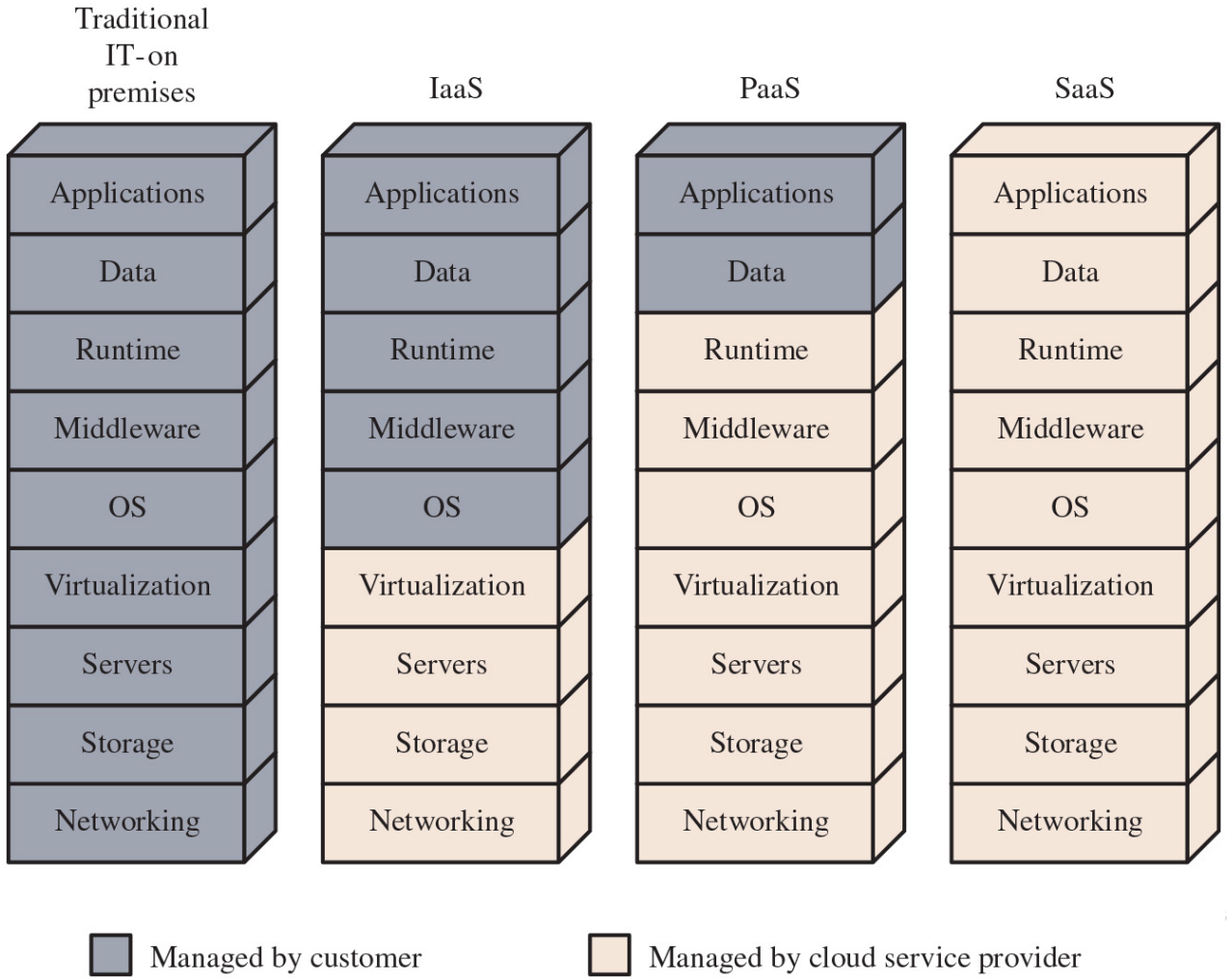
- Due to the nature of cloud computing, traditional infrastructure security measures based on the control of physical communication paths and insertion of security appliances do not work.
- Custom cloud security tools include virtual appliances and software agents that are used to secure virtual environments. However, these tools may introduce bottlenecks when accessing resources, or lead to processor overloading. Therefore, the use of virtual appliances should be carefully evaluated and deployed.
- Software-defined networks (SDN) enable new types of security controls and provide an overall gain for network security including:
    - Easy network isolation without constraints of physical hardware
    - SDN firewalls (security groups in cloud computing) applied to assets based on more flexible criteria than hardware firewalls

Cloud Security Responsibilities

- Cloud computing involves cloud clients and Cloud Service Providers (CSPs). Therefore, cloud security works in a ***shared responsibility*** model.
- A CSP is responsible for the cloud services to the client, however, the client is responsible for the rest of services. The sharing of responsibilities varies according to the type of cloud deployment.
- The following table displays the security implementation responsibility between a client and a CSP in different cloud service models.

Cloud Security Responsibilities (Cont.)

Figure displays the security implementation responsibility between a client/customer and a CSP (cloud service provider) in different cloud service models.



Other Cloud Infrastructure Security Considerations

Company Security Policies:

- An organization may permit users to download unknown software tools.
- Un-sanctioned apps may increase employee productivity by permitting them to download and use their favorite software tools.
- Unmonitored apps can create security gaps and blind spots.
- Established, well-defined company security policies and educating users are effective ways to manage unknown apps.

Other Cloud Infrastructure Security Considerations (Cont.)

Layered Security:

- Cloud resources can be viewed in four layers; hardware, infrastructure, platform, and application layers. ***Defense-in-depth*** strategies can be applied to each of these layers.

- Some layered security options are:
  - Cloud platforms typically have built-in security at the platform level to protect client cloud resources. For example, some CSPs provide built-in DDoS service that clients do not need to configure.
  - A virtual private cloud allocates private subnets that are logically isolated from the internet.
  - While clients will not have access to configure physical firewall devices, CSPs typically provide equivalent firewall functions, or virtual firewalls, such as deny and allow rules and host-level security groups.
  - Flow logs are used to monitor traffic that crosses individual network interfaces.
  - VPNs are used to provide remote user access to the cloud resources, as well as site-to-site connections used in multi-cloud scenarios, or connections between a cloud and on-premises data centers.
  - Identity and access management (IAM) services provide user credential management and user authentication and authorization management. Proper use of IAM is critical to protect cloud resources from being abused.

Other Cloud Infrastructure Security Considerations (Cont.)

Microsegmentation:

- Also referred to as hypersegregation, microsegmentation leverages virtual network topologies to run multiple, smaller, and more isolated networks without incurring additional hardware costs.
- Because the networks are entirely defined in software without many of the traditional addressing issues, it is far more feasible to run these multiple, software-defined environments.
- Microsegmentation techniques allow for more granular control of security for traffic and workflows within the cloud.

4. Cloud Application Security

Application Development (Cont.)

To maintain security at all stages of **application development**, the following robust process needs to be followed.

Developing and testing:

- Software is developed and updated in a development environment, where it can be developed, tested, and debugged before being deployed.
- A development environment is less restrictive than the live environment and has a lower security level.
- Version control software helps track and manage changes to the software code.
- Developers may also work in a sandbox environment so that code is not overwritten as they develop it.
- During testing, developers look at how the code interacts with the normal environment.
    - Quality assurance (QA) can find defects in the software. It is much easier to fix any defect found at this phase.

Application Development (Cont.)

Provisioning and deprovisioning:

- Provisioning is the creation or updating of software.
- Deprovisioning is its removal.
- An organization can use a self-service portal to automate software provisioning and deprovisioning.

Staging and production:

- Staging environments should closely match the organization's production environment.
- By testing in a staging environment, developers can verify that the software runs under the required security settings.
- After the developer runs and tests security, the program can be deployed to production.

Securing Coding Techniques

When coding applications, developers use several techniques to validate that all security requirements have been met.

Normalization is used to organize data in a database and help maintain data integrity. Normalization converts an input string to its simplest known form to ensure that all strings have unique binary representations and that any malicious input is identified.

Stored Procedure: A stored procedure is a group of precompiled SQL statements stored in a database that execute a task. If you use a stored procedure to accept input parameters from clients using different input data, you will reduce network traffic and get faster results.

Securing Coding Techniques (Cont.)

Obfuscation and camouflage
A developer can use obfuscation and camouflage to prevent software from being reverse engineered. Obfuscation hides original data with random characters or data. Camouflage replaces sensitive data with realistic fictional data.

Code reuse means using existing software to build new software, saving time and development costs. Care must be taken, though, to avoid the introduction of vulnerabilities.

SDKs: Third-party libraries and software development kits (SDKs) provide a repository of useful code to make application development faster and cheaper. The downside is that any vulnerabilities in SDKs or third-party libraries can potentially affect many applications.

Input Validation

Controlling the data input process is key to maintaining database integrity. Many attacks run against a database and insert malformed data. Such attacks can confuse, crash, or make the application divulge too much information to the attacker.

Automated input attack example:

- Customers fill out a web application form to subscribe to a newsletter.
- A database application automatically generates and sends email confirmations back to the customers.
- When customers receive the email with a URL link to confirm their subscription, attackers have modified the URL link.
- These modifications can change the username, email address or subscription status of the customers when they click to confirm their subscription.
- Hackers can automate this attack to flood the web application with thousands of invalid subscribers to the newsletter database.

Validation Rules

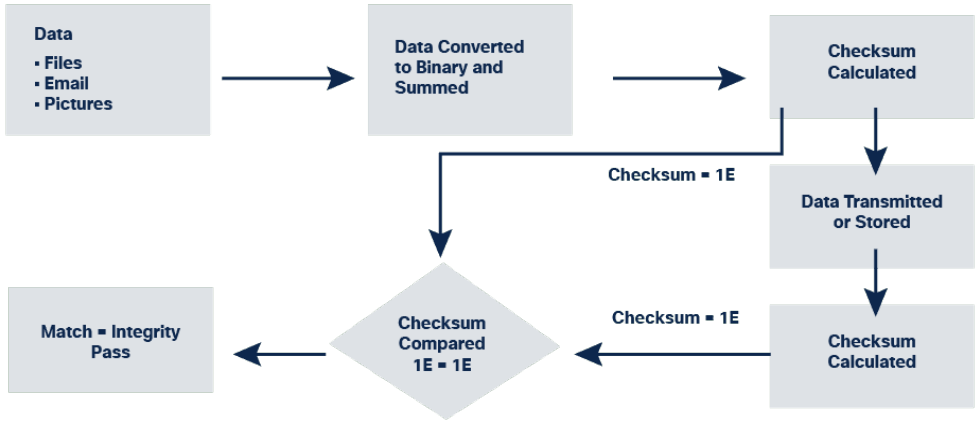
A validation rule checks that data falls within the parameters defined by the database designer. A validation rule helps to ensure the completeness, accuracy, and consistency of data. The criteria used in a validation rule include the following:

- **Size** – checks the number of characters in a data item
- **Format** – checks that the data conforms to a specified format
- **Consistency** – checks for the consistency of codes in related data items
- **Range** – checks that data lies within a minimum and maximum value
- **Check digit** – provides for an extra calculation to generate a check digit for error detection

Integrity Checks

Compromised data can threaten the security of your devices and systems.

An **integrity check** can measure the consistency of data in a file, picture, or record to ensure that it has not been corrupted. The integrity check performs a **hash function** to take a snapshot of data and then uses this snapshot to ensure data has remained unchanged. A **checksum** is an example of a hash function.



Integrity Checks (Cont.)

The checksum process includes:

- **How a checksum works:** A checksum verifies the integrity of files, or strings of characters, before and after they transfer between devices across a local network or the Internet.
  - Checksums convert each piece of information to a value and sum the total.
  - To test the data integrity, a receiving system repeats the process.
  - If the two sums are equal, the data is valid.
  - If not, a change has occurred somewhere along the line.

Integrity Checks (Cont.)

The checksum process includes:

- **Hash functions:** Common hash functions include MD5, SHA-1, SHA-256, and SHA-512. These use complex mathematical algorithms to compare data to a hashed value.
- **Version control:** Organizations use version control to prevent authorized users from making accidental changes. Version control means that two users cannot update the same object, such as a file, database record or transaction, at the exact same time.
- **Backups:** Accurate backups help to maintain data integrity if data becomes corrupted. An organization needs to verify its backup process to ensure the integrity of the backup.
- **Authorization** determines who has access to an organization's resources based on a need-to-know basis.

Other Application Security Practices

How can you be sure that a piece of software you are installing is authentic or that information is secure when browsing the Internet?

- **Code signing** helps prove that a piece of software is authentic.
  - Executables designed to install and run on a device are digitally signed to validate the author's identity and provide assurance that the software code has not changed since it was signed.

- **Secure cookies:** Using secure cookies protects information stored in cookies from hackers.
  - When your client system interacts with a server, the server sends an HTTP response that instructs your browser to create at least one cookie.
  - The cookie then stores data for future requests while you are browsing that website.
  - Web developers should use cookies with HTTPS, to secure cookies and prevent them from being transmitted over unencrypted HTTP.

5. Cloud Data Security

States of Data

The states of **Data Security Domain** describes controls related to securing the data itself, of which encryption and hashing are of the most important.

Customer data should be protected in the following three states:

- **Data at rest:** This refers to data that is in storage.
  - Data is in this state when no user or process is accessing, requesting, or amending it.
  - Data at rest can be stored on local devices such as a hard disk in a computer, or a centralized network, such as an organization's server.
  - In cloud computing, data at rest can be stored in a cloud and is accessible from any computer connected to the internet, usually with subscription.
  - All data that is not in transit nor in process is considered data at rest.

States of Data (Cont.)

- **Data in transit:** This refers to data which is being transmitted.
  - The data is not at rest, nor is it being processed.
  - The transmission could be within a single server along its motherboard's bus lines, between devices on a single network, or between networks and possibly across the internet.
  - Using cryptography and hashing to protect data in transit is critical for cloud computing.

- **Data in process:** This refers to data during initial input, modification, computation, or output.
  - Data is in this state when it is neither in transit nor at rest.
  - It is data that is being processed.

Cryptography

- **Cryptography** is the science of making and breaking secret codes.
  - By storing and transmitting encrypted data, only the intended recipient can read or process it, and only if they have proper knowledge of the secret used in the encryption algorithm.

- **Encryption** is the process of scrambling data so that unauthorized people cannot easily read it.
  - When enabling encryption, readable data is called plaintext, while the encrypted version is encrypted text or ciphertext.
  - Encryption converts the plaintext readable message to ciphertext, which is the unreadable, disguised message. Decryption reverses the process.
  - Encryption requires a key, which plays a critical role in encrypting and decrypting a message. The person possessing the key can decrypt the ciphertext to plaintext.

Cryptography (Cont.)

There are two classes of encryption algorithms:

- **Symmetric encryption algorithms** use the same pre-shared key to encrypt and decrypt data, a method also known as private key encryption.
  - The Advanced Encryption Standard (AES) is a symmetric encryption algorithm that has a fixed block size of 128 bits with a key size of 128, 192, or 256 bits.
  - The U.S. government uses AES to protect classified information.

- **Asymmetric encryption algorithms** use one key for encryption that is different from the key used for decryption.
  - Asymmetric encryption algorithms include Rivest-Shamir-Adleman (RSA), Diffie-Hellman, ElGamal, and Elliptic curve cryptography (ECC).

Hashing

- **Hashing** is a tool that ensures data integrity by taking binary data (i.e., the message) and producing a fixed-length representation called the hash value (i.e., message digest).

- **Hash functions** are one-way functions used to verify and ensure data integrity.
  - A hash tool can also verify authentication.
  - It works by using a cryptographic hashing function to replace plaintext passwords or encryption keys.
  - A cryptographic hash function has the following properties:
    - The input can be any length.
    - The output has a fixed length.
    - The hash function is one-way and is not reversible.
    - Two different input values will almost never result in the same hash.

6. Protecting VMs

Protecting Virtual Machines

- Virtual Machines (VMs or VM instances), just like a physical computer, require patches, updates, and antimalware measures to protect them from external threats.

- The cloud offers additional security options, depending on the specific tools available in a cloud platform, to protect VMs including:

  Plan subnet placement: Carefully choose the subnet for each instance so that it has only the necessary access to the outside world.

  Disable unneeded ports and services: Only enable ports and services that are needed to reduce unnecessary exposure to outside.

Protecting Virtual Machines (Cont.)

Enforce account management and policies: The OS in a VM has default user accounts. Deactivate any default user accounts and create user accounts with best-practice account management policies such as password complexity and least privilege access.

Install antivirus/antimalware software and keep it updated: This can be accomplished through the VM OS, or it might be available as a service from the cloud platform.

Install host-based/software firewall and IDP/IPS: This can be accomplished through the VM OS, or it might be available as a service from the cloud platform.

Protecting VMs from VM Sprawl Attacks

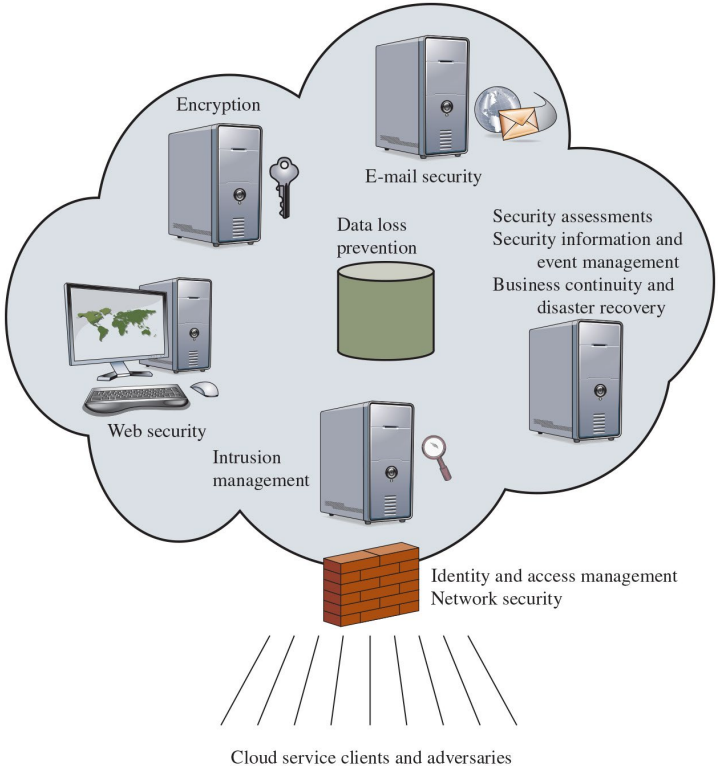
- Creating VM instances in a cloud is a relatively easy process.
  - This may lead to a VM Sprawl issue, where an organization has many VM instances that are not properly managed.
  - If these running instances are not monitored and maintained, they eventually become outdated and vulnerable to attacks.

- A cloud computing client should implement policies to log and audit cloud resources being used.
  - VM sprawl not only presents potential risks, but it also consumes cloud services unnecessarily, such as VM instances, storage, and unassigned public IP addresses.
  - By logging the use of cloud resources, monitoring the running VMs, and auditing the actual usage, an organization can better manage and protect the VMs they really need.

Cloud Security as a Service

- In the context of cloud computing, cloud security as a service, designated SecaaS, is a segment of the SaaS offering of a CSP
- The CSA defines SecaaS as the provision of security applications and services via the cloud either to cloud-based infrastructure and software, or from the cloud to the customers' on-premise systems
- The CSA has identified the following SecaaS categories of service:
  - Identity and access management
  - Data loss prevention
  - Web security
  - E-mail security
  - Security assessments
  - Intrusion management
  - Security information and event management
  - Encryption
  - Business continuity and disaster recovery
  - Network security

Elements of Cloud Security as a Service



7. IoT Security

The Internet of Things (IoT)

- IoT is a term that refers to the expanding interconnection of smart devices, ranging from appliances to tiny sensors
  - A dominant theme is the embedding of short-range mobile transceivers into a wide array of gadgets and everyday items, enabling new forms of communication between people and things and between things themselves
  - The Internet supports the interconnectivity usually through cloud systems
- The objects deliver sensor information, act on their environment, and, in some cases, modify themselves to create overall management of a larger system
- The IoT is primarily driven by deeply embedded devices
  - These devices are low-bandwidth, low-repetition data capture and low-bandwidth data-usage appliances that communicate with each other and provide data via user interfaces
  - Embedded appliances, such as high-resolution video security cameras, video VoIP phones, and a handful of others, require high-bandwidth streaming capabilities

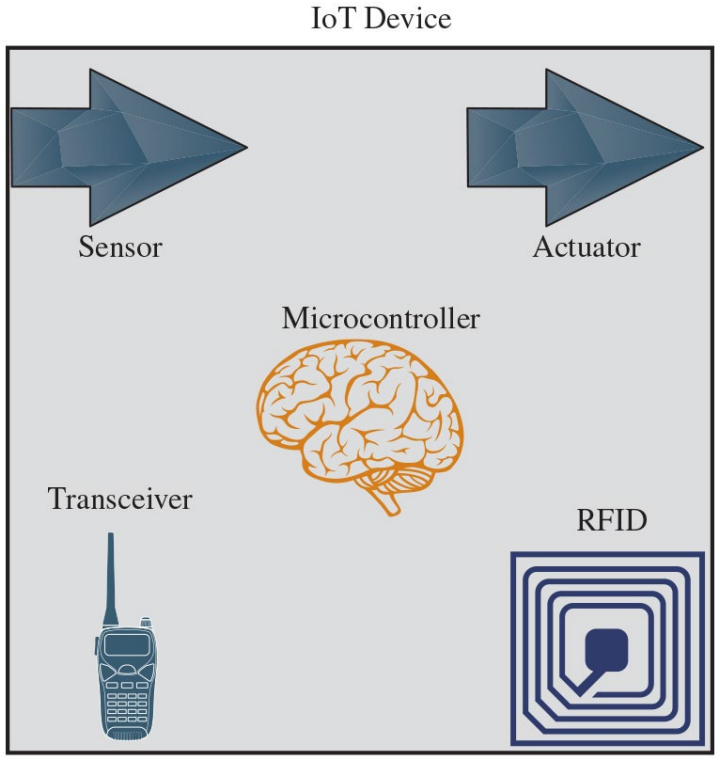
Evolution (1 of 2)

- With reference to the end systems supported, the Internet has gone through roughly four generations of deployment culminating in the IoT:
  - **Information technology (IT)**
    - PCs, servers, routers, firewalls, and so on bought as IT devices by enterprise IT people primarily using wired connectivity
  - **Operational technology (OT)**
    - Machines/appliances with embedded IT built by non- I companies, such as medical machinery, SCADA, process control, and kiosks, bought as appliances by enterprise OT people primarily using wired connectivity
  - **Personal technology**
    - Smartphones, tablets, and eBook readers bought as I T devices by consumers (employees) exclusively using wireless connectivity and often multiple forms of wireless connectivity

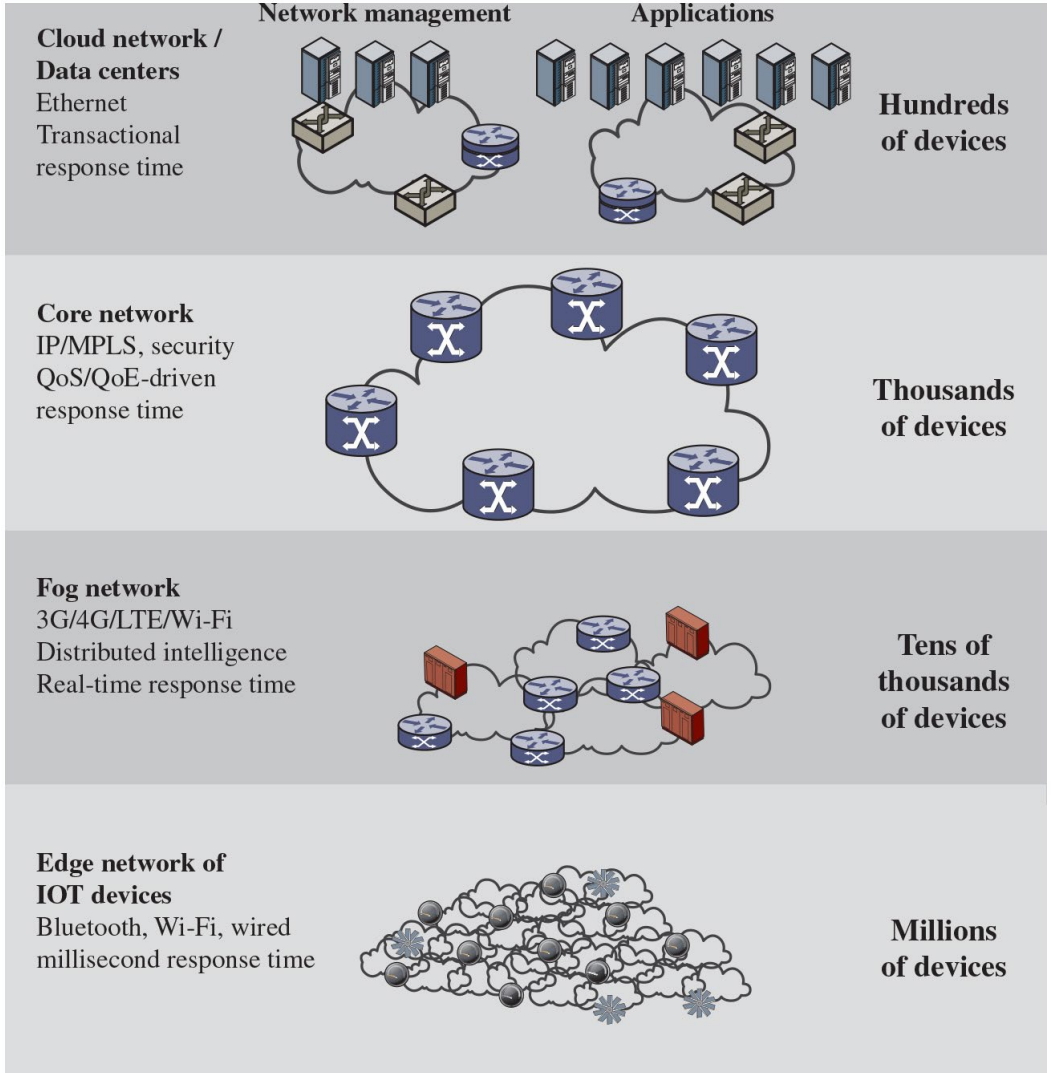
Evolution (2 of 2)

  - **Sensor/actuator technology**
    - Single-purpose devices bought by consumers, IT, and OT people exclusively using wireless connectivity generally of a single form as part of larger systems
- The fourth generation is usually thought of as the IoT and marked by the use of billions of embedded devices

IoT Components



The IoT/Cloud Context



Edge

- At the edge of a typical enterprise network is a network of IoT-enabled devices consisting of sensors and perhaps actuators
  - These devices may communicate with one another
  - A cluster of sensors may all transmit their data to one sensor that aggregates the data to be collected by a higher-level entity
- A gateway interconnects the IoT-enabled devices with the higher-level communication networks
  - It performs the necessary translation between the protocols used in the communication networks and those used by devices
  - It may also perform a basic data aggregation function

Fog (1 of 2)

- In many IoT deployments, massive amounts of data may be generated by a distributed network of sensors
- Rather than store all of that data permanently (or at least for a long period) in central storage accessible to IoT applications, it is often desirable to do as much data processing close to the sensors as possible
- The purpose of what is sometimes referred to as the edge computing level is to convert network data flows into information that is suitable for storage and higher-level processing
- Processing elements at these levels may deal with high volumes of data and perform data transformation operations, resulting in the storage of much lower volumes of data
- The following are examples of fog computing operations:
  - Evaluation
  - Formatting
  - Expanding/decoding
  - Distillation/reduction
  - Assessment

Fog (2 of 2)

- Generally, fog computing devices are deployed physically near the edge of the IoT network near the sensors and other data-generating devices
- Fog computing and fog services are expected to be a distinguishing characteristic of the IoT
- Fog computing represents an opposite trend in modern networking from cloud computing
  - With cloud computing, massive, centralized storage and processing resources are made available to distributed customers over cloud networking facilities to a relatively small number of users
  - With fog computing, massive numbers of individual smart objects are interconnected with fog networking facilities that provide processing and storage resources close to the edge devices in an IoT
- Fog computing addresses the challenges raised by the activity of thousands or millions of smart devices, including security, privacy, network capacity constraints, and latency requirements
- The term fog computing is inspired by the fact that fog tends to hover low to the ground whereas clouds are high in the sky

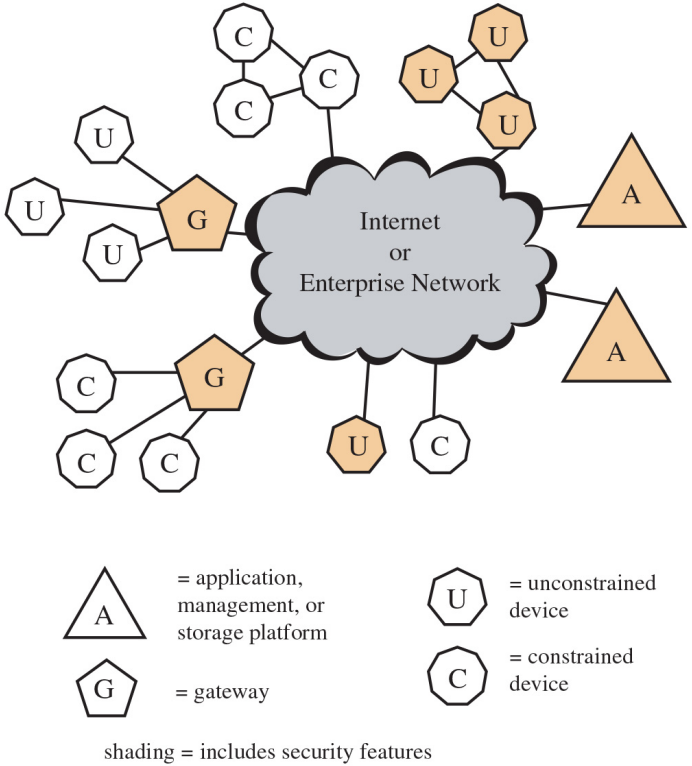
Core

- The core network, also referred to as a backbone network, connects geographically dispersed fog networks as well as providing access to other networks that are not part of the enterprise network
- Typically, the core network will use very high-performance routers, high-capacity transmission lines, and multiple interconnected routers for increased redundancy and capacity
- The core network may also connect to high-performance, high-capacity servers such as large database servers and private cloud facilities
- Some of the core routers may be purely internal, providing redundancy and additional capacity without serving as edge routers

Comparison of Cloud and Fog Features

	Cloud	Fog
Location of processing/storage resources	Center	Edge
Latency	High	Low
Access	Fixed or wireless	Mainly wireless
Support for mobility	Not applicable	Yes
Control	Centralized/hierarchical (full control)	Distributed/hierarchical (partial control)
Service access	Through core	At the edge/on handheld device
Availability	99.99%	Highly volatile/highly redundant
Number of users/devices	Tens/hundreds of millions	Tens of billions
Main content generator	Human	Devices/sensors
Content generation	Central location	Anywhere
Content consumption	End device	Anywhere
Software virtual infrastructure	Central enterprise servers	User devices

IoT Security: Elements of Interest



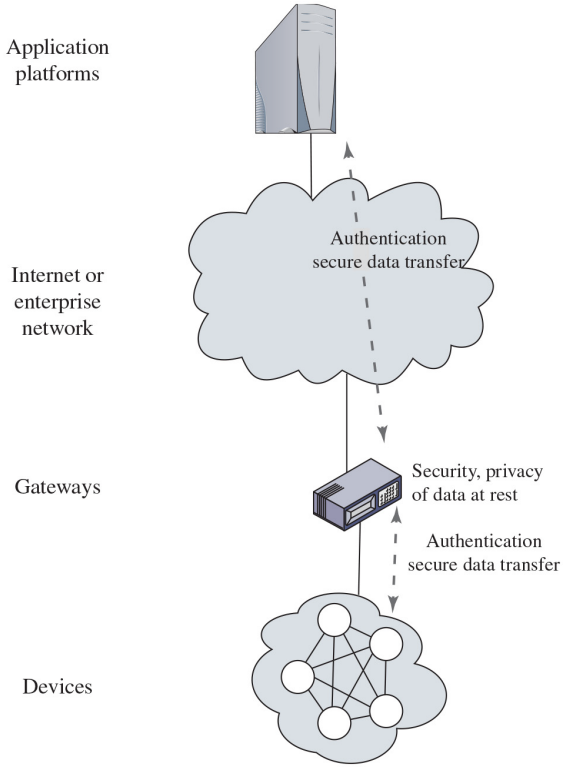
Patching Vulnerability

- There is a crisis point with regard to the security of embedded systems, including I o T devices
- The embedded devices are riddled with vulnerabilities, and there is no good way to patch them
- Chip manufacturers have strong incentives to produce their product as quickly and cheaply as possible
- The device manufacturers focus is the functionality of the device itself
- The end user may have no means of patching the system or, if so, little information about when and how to patch
- The result is that the hundreds of millions of Internet-connected devices in the I o T are vulnerable to attack
- This is certainly a problem with sensors, allowing attackers to insert false data into the network
- It is potentially a graver threat with actuators where the attacker can affect the operation of machinery and other devices

IoT Security and Privacy Requirements

- ITU-T Recommendation Y.2066 includes a list of security requirements for the IoT
- The requirements are defined as being the functional requirements during capturing, storing, transferring, aggregating, and processing the data of things, as well as to the provision of services that involve things
- The requirements are:
  - Communication security
  - Data management security
  - Service provision security
  - Integration of security policies and techniques
  - Mutual authentication and authorization
  - Security audit

IoT Gateway Security Functions



IoT Security Environment

